

IntelliAudit: Using Large Language Models to Evaluate Audit Controls

Anonymous Author(s)

Abstract

IT audits are labor-intensive, evidence-heavy processes that require trained professionals to evaluate organizational controls across a wide range of artifact types. While prior work has explored LLM integration in compliance and security assurance workflows, no published system has specifically targeted the evidence evaluation phase of IT auditing as a structured, explainable, and human-supervised task. This paper presents IntelliAudit, a multi-agent LLM pipeline designed to assist auditors in assessing the compliance status of organizational controls against the ISO/IEC 27001:2022 standard. IntelliAudit decomposes control assessment into four co-operating agents: a Retriever, which performs adaptive evidence search over an organizational artifact corpus; an Auditor, which conducts the primary requirement-level evaluation; a Defender, which challenges adverse findings by seeking mitigating or overlooked evidence; and a Judge, which performs independent adjudication when the Auditor and Defender disagree. The system is implemented as a conversational, human-in-the-loop tool that preserves auditor judgment as the authoritative decision-making authority. We evaluate IntelliAudit against a benchmark of 15 ISO 27001:2022 controls spanning policy documents, structured spreadsheets, images, and video artifacts, using a cross-model validation approach with OpenAI GPT-5-Nano and Claude Sonnet 4.5, supplemented by a human survey of practicing auditors and compliance professionals. Our results demonstrate that both models successfully evaluated all artifact types within their context window constraints, and that the multi-agent architecture produced measurably stronger reasoning outputs than the single-agent ablation condition. These findings suggest that structured, retrieval-grounded multi-agent pipelines are a viable and practically useful approach to LLM-assisted IT audit automation.

ACM Reference Format:

Anonymous Author(s). 2026. IntelliAudit: Using Large Language Models to Evaluate Audit Controls. *J. ACM* 37, 4, Article 111 (July 2026), 11 pages. <https://doi.org/XXXXXXX.XXXXXXX>

1 Introduction

RQ1: Can LLMs understand audit controls beyond the plain text language?

RQ2: Can LLMs factually and accurately evaluate the completeness of supporting evidence?

Permission to make digital or hard copies of all or part of this work for personal or classroom use is granted without fee provided that copies are not made or distributed for profit or commercial advantage and that copies bear this notice and the full citation on the first page. Copyrights for components of this work owned by others than the author(s) must be honored. Abstracting with credit is permitted. To copy otherwise, or republish, to post on servers or to redistribute to lists, requires prior specific permission and/or a fee. Request permissions from permissions@acm.org.

© 2026 Copyright held by the owner/author(s). Publication rights licensed to ACM. ACM 1557-735X/2026/7-ART111
<https://doi.org/XXXXXXX.XXXXXXX>

RQ3: Does the reasoning capability extend to multi-modal artifacts?

RQ4: Does the reasoning capability enable non-audit experts to better prepare their organization for an audit?

2 Background

Audits are systematic, independent examinations of an organization's financial records, internal controls, and operational processes to assess their accuracy, compliance with regulations, and adherence to established standards. They serve multiple critical functions in the business ecosystem: providing stakeholders with reliable assurance about financial reporting integrity, identifying operational inefficiencies and areas for improvement, ensuring compliance with legal and regulatory requirements, and detecting potential fraud or mismanagement. Audits enhance organizational transparency, build public confidence, facilitate better decision-making through verified information, and ultimately contribute to market stability and trust. In an era of increasing regulatory complexity and stakeholder scrutiny, audits have become indispensable tools for risk management, corporate governance, and maintaining the credibility of financial markets. INTELLIAUDIT proposes the use of AI agents to help automate this process.

The audit process typically follows a structured, multi-phase approach that begins with planning and risk assessment, occurring during a kick-off meeting, where auditors gain an understanding of the client's business, industry, and internal control systems to identify areas of highest risk and determine the scope and nature of audit procedures. During the fieldwork phase, auditors identify relevant organizational controls and the organization provides evidence for the implementation of those controls. This is followed by the evaluation phase, where auditors assess the sufficiency and appropriateness of audit evidence collected, identify any material misstatements or control deficiencies, and form conclusions about the fair presentation of financial statements or the effectiveness of the audited processes. The process concludes with reporting, where auditors communicate their findings through formal audit reports.

3 Related Work

There is limited published research in the field of AI-powered IT audits, with existing industry solutions and publications focused on technological compliance enforcement rather than control and evidence evaluation itself.

3.1 General Agentic AI Automation

Liu [1] explored multi-agent LLM collaboration for incident response using the Backdoors and Breaches tabletop framework, evaluating centralized, decentralized, and hybrid agent team configurations, and finding that multi-agent architectures improved decision-making in security operations. This provides architectural precedent for a Auditor-Defender-Judge model. Complementing

this, Agarwal et al. [2] proposed RAGulating Compliance, a multi-agent system that builds a structured map of relationships between regulatory concepts, which it uses alongside document retrieval to answer compliance questions accurately and verifiably. A study on human and AI collaboration in LLM auditing by Rostogi et al [7] introduced AdaTest++. Inspired by the AdaTest framework, it demonstrated that collaborative human-AI auditing detects a wider range of failure modes, which includes previously under-reported ones than human or automated solutions independently could not detect, providing grounding for human-in-the-loop audit workflows. Amirzani et al [8] proposed a solution that audits an LLM by using a different LLM alongside human-in-the-loop verification which avoids circular self-validation while offering transparency and verifiability. This supports our cross-model validation approach. Chan et al [9] introduces D3, an evaluation system comprised of multi-agents in a courtroom-inspired architecture that routes evaluations through structured adversarial debate to address positional bias, verbosity bias and self-enhancement bias that simple single LLM judges are prone to. Proposed by Du et al [10], “society of minds”, is an approach where multiple LLMs propose answers independently and debate their responses over multiple iterations until concluding with a final answer which demonstrates improvements in strategic reasoning and factuality of generated content, helping to reduce hallucinations that ordinary models are susceptible to. Lastly, a paper by Ruan et al [11] demonstrates the potential of multi-agent pipelines on structured security reasoning tasks by using agents to collaborate on intelligence gathering, vulnerability analysis, and exploitation stages in security workflows. This is similar to our Auditor-Defender-Judge architecture.

3.2 Cybersecurity GRC Automation

Kramer et al. [3] evaluated LLMs for automating the terminal phase of security incident response, specifically the production of investigation summaries for stakeholders, auditors, and legal experts. Studying 18 security analysts across 50 real-world incidents, they found that fully autonomous LLM operation omitted critical details in 35% of cases and introduced factual inaccuracies in 42%, while a human-assisted collaborative mode substantially improved output quality. Amaral et al [12] proposes an automated NLP-based compliance checking that not only analyses whether agreements are complaint, but provides recommendations about missing information in data processing agreements, which provides an average accuracy gain of about 20 percent compared to baselines that rely on off-the-shelf NLP tools. This idea is very similar to our concept of partial/non-compliant outputs with gap recommendations. M.InTosh et al [13] assessed the readiness of four GRC frameworks, including ISO 27001:2022, for LLM integration by using both human experts and LLMs, and concluded on the crucial and urgent need for human-expert-in-the-loop validation processes to enhance cyber security frameworks. Waiker et al [14] evaluated retrieval-augmented (RAG) generative AI methods for assessing and confirming compliance and providing reasoning for deficiencies in clinical pharmacology documents, demonstrating RAG-based compliance evaluation extends across domains beyond IT security. Another RAG system developed by Hillebrand et al [15] enhances compliance query processing using hybrid search and relevance boosting.

This paper was evaluated on 124 expert-annotated queries and demonstrates progress over traditional RAG approaches.

3.3 Audit Automation

Brachten et al. [4] conducted a feasibility study on automating ISO 27001 consultancy and auditing using AI, interviewing six ISO 27001 practitioners across sectors including healthcare and finance to map the common auditing workflow and identify its most resource-intensive tasks. Their analysis found consensus on the value of LLMs, particularly in the evaluation and reporting phase, with benefits including time efficiency and improved document quality, while significant concerns remained around the handling of sensitive organizational information and the accuracy of AI-generated content. In a related study, an early pilot evaluation of LLM utilization on ISO 27001 audit planning tasks [5] provided an empirical baseline for LLM performance. In industry research, Yao et al. [6] at Apple proposed a smart audit system empowered by LLMs for manufacturing supply chain audits. Their system introduced a dynamic risk assessment model and a compliance copilot for evidence retrieval and evaluation, achieving an improvement of around 24% in audit efficiency with negligible loss of accuracy, demonstrating the practical viability of LLM-assisted audit workflows at scale. A survey by Leocadio et al [16], performing a systemic review of AI, machine learning, blockchain and IoT in accounting and auditing explores digital transformation in auditing processes, discusses the ethical issues for reliable use, and underlines the advantages of organizations incorporating AI in auditing processes to foster innovation. Furthermore, DocLLM, a lightweight LLM extension by Wang et al [17], performs reasoning over visual enterprise documents such as forms, invoices, receipts, reports, and contracts as visual cues from complex layouts play an important role in comprehension. This supports our claim that multi-modal artifact handling of XLS, PNG, and MP4 is meaningful.

This body of work establishes both the practical demand for LLM-assisted audit and compliance tooling and the consistent finding that human oversight remains essential.

4 Conceptual Auditing Model

We propose a general conceptual model for auditing that captures the structural dependencies among audit requirements, the artifact types that can substantiate those requirements, and the explainable recommendation task that INTELLIAUDIT performs for auditors. The model is intentionally domain-agnostic and can be instantiated for security, privacy, financial, or regulatory audits by specializing the requirement set and artifact taxonomy. INTELLIAUDIT is a chat bot that works alongside the auditor. Initially collecting both the relevant controls and policy documents for those controls and providing followup questions during the kick-off meeting to better understand the system under assessment. INTELLIAUDIT will then ask for samples of relevant supporting evidence, before assessing the completeness of the control’s implementation, asking for more samples if necessary. Culminating in the generation of a report

4.1 Audit Requirement Graph

Let $R = \{r_1, r_2, \dots, r_n\}$ denote the set of audit requirements defined by a given standard or regulatory framework. We model prerequisite relationships among requirements as a directed graph $G = (R, \mathcal{P})$, where an edge $(r_i, r_j) \in \mathcal{P}$ indicates that requirement r_i must be satisfied before requirement r_j can be meaningfully evaluated.

The graph G induces a partial order over R and is assumed to be acyclic, reflecting the logical constraint that an audit requirement cannot depend on its own satisfaction. A *critical path* is defined as any maximal directed path

$$r_{i_1} \rightarrow r_{i_2} \rightarrow \dots \rightarrow r_{i_k},$$

where the satisfaction of each requirement is a prerequisite for the next. Requirements appearing earlier along a critical path represent foundational conditions whose absence invalidates downstream audit claims.

For computational purposes, G can be encoded as a dependency matrix $D \in \{0, 1\}^{n \times n}$, where $D_{ij} = 1$ if and only if $(r_i, r_j) \in \mathcal{P}$. This representation enables automated traversal and identification of blocking requirements.

4.2 Artifact–Requirement Mapping

Each audit requirement $r_i \in R$ must be supported by one or more evidentiary artifacts. Let $\mathcal{A}$ denote the universe of acceptable artifacts. We define a mapping

$$\alpha : R \rightarrow 2^{\mathcal{A}},$$

where $\alpha(r_i)$ specifies the set of artifact types acceptable as evidence for satisfying r_i . For a target requirement r_i , the mapping $\alpha(r_i)$ defines the admissible evidence types that an audit assistant should seek and cite.

Artifacts are classified into a finite taxonomy that may include policy and procedure documents, records and logs, configuration snapshots, architectural diagrams, images, and recorded video evidence. Certain artifact types may serve as substitutes for others depending on audit constraints (e.g., remote audits replacing physical inspections with video evidence).

4.3 Audit State and Evaluation

Let $S \subseteq R$ denote the set of requirements currently satisfied by an organization. A requirement r_j is *evaluable* at audit time if and only if all of its prerequisites have been satisfied, i.e.,

$$\forall r_i \in R : (r_i, r_j) \in \mathcal{P} \Rightarrow r_i \in S.$$

This condition formalizes the notion of audit readiness and prevents premature evaluation of dependent requirements. In operational terms, requirements that are not yet evaluable should be surfaced as prerequisite gaps rather than assigned a substantive compliance finding.

4.4 Explainable Audit Recommendation Task

Given an evaluable requirement $r_j \in R$ and an engagement-specific evidence corpus $\mathcal{E} \subseteq \mathcal{A}$, INTELLIAUDIT computes

$$F(r_j, \mathcal{E}, S) \rightarrow (\hat{y}_j, \mathcal{B}_j, \Xi_j),$$

where

$$\hat{y}_j \in \{\text{COMPLIANT}, \text{PARTIAL}, \text{NON_COMPLIANT}, \text{INSUFFICIENT_EVIDENCE}\}$$

is an auditor-facing recommendation, $\mathcal{B}_j$ is the supporting evidence for requirement r_j , and Ξ_j is a structured explanation that shows how the evidence maps to the criteria, highlights any gaps or uncertainties, and suggests follow-up or remediation actions.

The goal is not autonomous certification. Rather, the system produces an inspectable recommendation package that a human auditor can review, challenge, and incorporate into the broader audit workflow. This formulation makes explainability first-class: the status recommendation is only meaningful when paired with supporting evidence and a usable rationale. By jointly modeling requirement dependencies, admissible artifact types, and auditor-facing outputs, the framework provides a formal foundation for the methodology presented in the following Section.

5 Methodology

For a target evaluable requirement r_j , the method is organized as a multi-agent pipeline consisting of one shared retrieval agent and three decision agents:

- (1) *Retriever*, which retrieves candidate artifacts from $\mathcal{E}$ for a specific information need.
- (2) *Auditor*, which performs the primary requirement-level assessment.
- (3) *Defender*, which challenges adverse or incomplete auditor findings by seeking mitigating or overlooked evidence.
- (4) *Judge*, which performs final adjudication when the auditor and defender disagree.

This decomposition is motivated by two methodological requirements. First, compliance auditing is inherently iterative and evidence-driven: planning, retrieval, evaluation, and synthesis are distinct reasoning steps and should be represented explicitly. Second, adverse findings should remain contestable prior to finalization. The resulting workflow therefore separates primary assessment, adversarial review, and independent judgment.

At the orchestration level, execution follows a deterministic policy:

- (1) The Auditor always runs for the target control.
- (2) The Defender runs only if the auditor returns PARTIAL or NON_COMPLIANT, because these are the cases where missed counterevidence would most undermine fairness and usefulness.
- (3) The Judge runs only if the defender proposes a status change relative to the auditor.

This policy reduces unnecessary computation on straightforward cases while preserving additional scrutiny for uncertain or contested decisions.

Figure 1 presents the full staged workflow, including requirement and evidence inputs, conditional agent invocation, retrieval-loop behavior, and structured auditor-facing outputs.

5.1 Control Assessment Procedure

The overall method is summarized in Algorithm 1.

IntelliAudit Methodology: Stages Multi-Agent Retrieval-Grounded Work

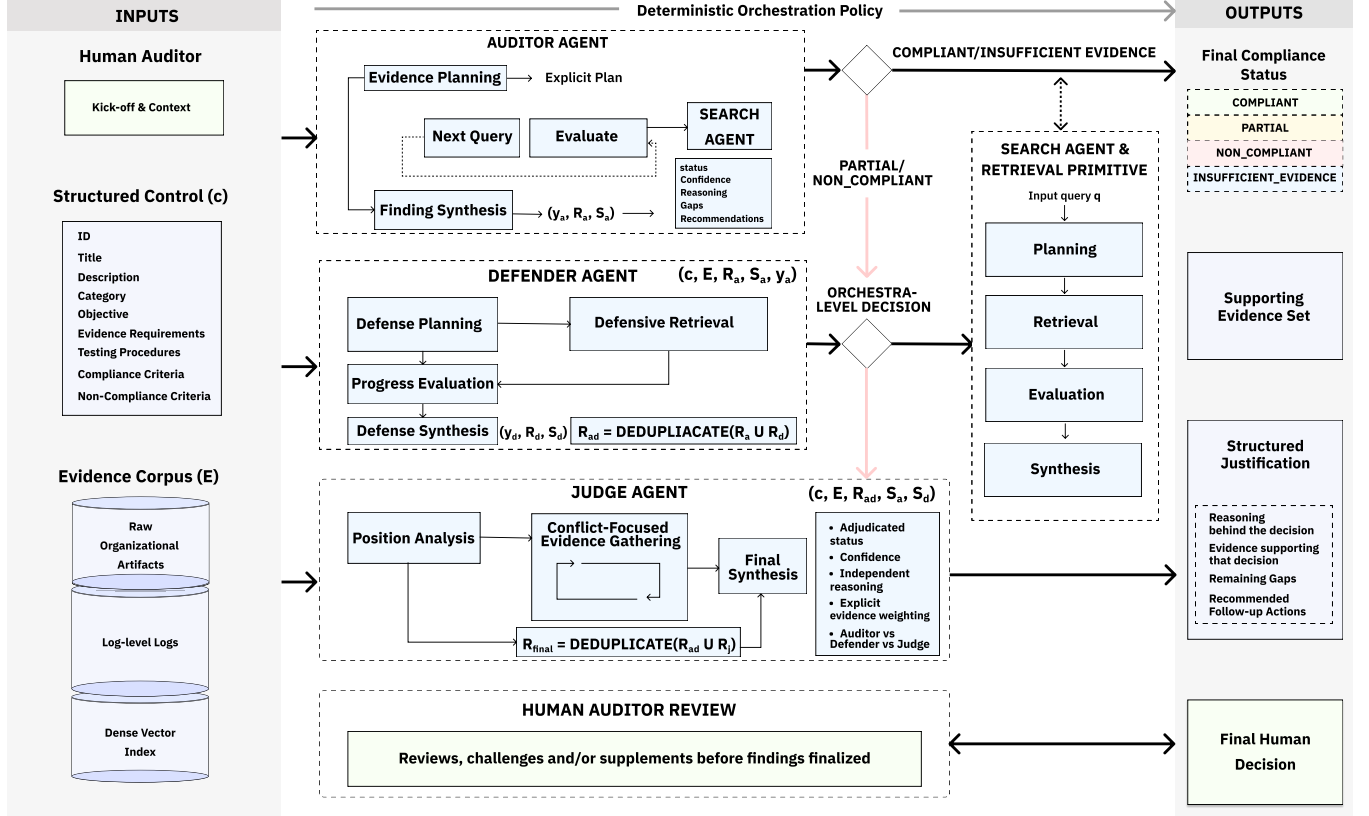


Figure 1: IntelliAudit Methodology: Staged Multi-Agent Retrieval-Grounded Workflow.

Algorithm 1 IntelliAudit Control Assessment

Require: Evaluable requirement r_j ; evidence corpus $\mathcal{E}$
Ensure: Final recommendation $\hat{y}_j$; cited evidence bundle $\mathcal{B}_j$; structured explanation Ξ_j

- 1: $(\mathcal{B}_A, \Xi_A, \hat{y}_A) \leftarrow \text{AUDITOR}(r_j, \mathcal{E})$
- 2: **if** $\hat{y}_A \notin \{\text{PARTIAL}, \text{NON_COMPLIANT}\}$ **then**
- 3: **return** $(\hat{y}_A, \mathcal{B}_A, \Xi_A)$
- 4: **end if**
- 5: $(\mathcal{B}_D, \Xi_D, \hat{y}_D) \leftarrow \text{DEFENDER}(r_j, \mathcal{E}, \mathcal{B}_A, \Xi_A, \hat{y}_A)$
- 6: $\mathcal{B}_{AD} \leftarrow \text{DEDUPLICATE}(\mathcal{B}_A \cup \mathcal{B}_D)$
- 7: **if** $\hat{y}_D = \hat{y}_A$ **then**
- 8: **return** $(\hat{y}_A, \mathcal{B}_{AD}, \text{COMBINE}(\Xi_A, \Xi_D))$
- 9: **end if**
- 10: $(\mathcal{B}_J, \Xi_J, \hat{y}_J) \leftarrow \text{JUDGE}(r_j, \mathcal{E}, \mathcal{B}_{AD}, \Xi_A, \Xi_D)$
- 11: $\mathcal{B}^* \leftarrow \text{DEDUPLICATE}(\mathcal{B}_{AD} \cup \mathcal{B}_J)$
- 12: **return** $(\hat{y}_J, \mathcal{B}^*, \Xi_J)$

All three decision agents follow the same high-level reasoning pattern: they construct an evidence-gathering strategy, retrieve evidence, evaluate whether further search is warranted, and then synthesize a structured output. The shared retrieval pattern is shown in Algorithm 2.

Algorithm 2 Generic Retrieval-Grounded Agent Pattern

Require: Agent-specific input x ; evidence corpus $\mathcal{E}$
Ensure: Gathered evidence $\mathcal{B}$; structured agent output Ξ ; optional status decision $\hat{y}$

- 1: $P \leftarrow \text{PLAN}(x)$
- 2: $\mathcal{B} \leftarrow \emptyset$
- 3: **repeat**
- 4: $q \leftarrow \text{NEXT_QUERY}(P)$
- 5: $\mathcal{B} \leftarrow \mathcal{B} \cup \text{SEARCH}(q, \mathcal{E})$
- 6: $\mathcal{B} \leftarrow \text{DEDUPLICATE}(\mathcal{B})$
- 7: $d \leftarrow \text{EVALUATE}(x, P, \mathcal{B})$
- 8: **if** $d = \text{STOP}$ **then**
- 9: **break**
- 10: **else if** d adds new queries **then**
- 11: $P \leftarrow \text{UPDATE_PLAN}(P, d)$
- 12: **end if**
- 13: **until** SAFETY_LIMIT_REACHED
- 14: $(\Xi, \hat{y}) \leftarrow \text{SYNTHESIZE}(x, P, \mathcal{B})$
- 15: **return** $(\mathcal{B}, \Xi, \hat{y})$

5.2 Control and Evidence Representation

Structured Control Representation. In the implementation, each control is a structured instantiation of an abstract requirement r_j . The record includes an identifier, title, description, objective, prerequisite metadata, admissible evidence types $\alpha(r_j)$, testing procedures, compliance criteria, and non-compliance criteria. This bridges the conceptual model of Section 3 to operational reasoning: the agents do not reason over raw control prose alone, but over an explicit representation of what counts as evidence and what constitutes success or failure.

Evidence Normalization. Organizational artifacts drawn from $\mathcal{A}$ are normalized into document objects with provenance metadata and stable identifiers, yielding the engagement-specific corpus $\mathcal{E}$. The method supports multiple evidence modalities that can be converted into textual retrieval units, including narrative documents and operational records.

Longer textual artifacts are segmented into overlapping chunks so that retrieval operates over semantically coherent units without requiring entire documents to be embedded as single vectors. Sources that are already naturally atomic, such as line-oriented logs, can instead be retained at their native granularity. This distinction improves retrieval precision while preserving sufficient local context for downstream reasoning.

Dense Retrieval and Deduplication. Evidence retrieval is performed over a dense vector index with cosine-based similarity ranking. Given a search query, the system retrieves the highest-ranked candidate evidence items and filters low-relevance results before passing them to downstream reasoning stages.

Because the same artifact may be retrieved by multiple semantically related queries, the method performs identifier-based deduplication before evaluation and synthesis. When duplicate evidence items are found, the system retains the highest-scoring instance and records retrieval-frequency metadata. This prevents repeated retrieval from being mistaken for independent corroboration while preserving information about how often a given item was surfaced.

5.3 System Design and Human-in-the-Loop Rationale

The goal of INTELLIAUDIT is to be implemented as a conversational agent rather than a fully automated pipeline. This design decision reflects a fundamental constraint in applying LLM-based reasoning to audit contexts: the enormous variance in how different organizations implement the same control. ISO 27001:2022 is deliberately flexible in how it permits controls to be operationalized, which means that any system operating without human oversight risks misclassifying a legitimately compliant implementation that simply differs from what the model expected to see. To manage this, INTELLIAUDIT has implemented a pilot a human-in-the-loop workflow for the first control, in which the system conducts a structured kick-off interaction to establish organizational context: requests specific artifact populations for each control under evaluation, produces a preliminary compliance assessment with explicit reasoning, and invites the auditor to review, challenge, or supplement that assessment before any finding is finalized. This architecture allows the semantic reasoning capabilities of the underlying LLM to accelerate

the evidence evaluation process while preserving the professional judgment of the auditor as the authoritative decision-maker.

5.4 Retriever Agent

The Retriever agent serves as the shared retrieval primitive used by all downstream agents. Its role is to convert an information need into an adaptive search process over the evidence corpus $\mathcal{E}$ and produce candidate evidence bundles for later judgment.

Planning. Given an information need q , the Retriever agent first generates a short search plan consisting of one or more semantically distinct queries. The purpose of this stage is not to answer the question directly, but to decompose the retrieval problem into complementary probes that target different aspects of the same information need.

Retrieval. Each planned query is executed against the dense index. Retrieved items are accumulated together with their similarity scores and provenance. The Retriever agent also tracks whether newly retrieved items are distinct from previously seen items, enabling later stages to reason about search-space saturation rather than total result counts alone.

Evaluation. After the current plan has been executed, the Retriever agent evaluates whether additional retrieval is warranted. The evaluation stage may stop, continue with the existing plan, pivot to a different vocabulary, or expand the plan with new targeted queries. Importantly, this decision is based on evidence coverage and diminishing returns rather than on a fixed number of retrieved items alone.

Synthesis. The final Search-agent output is a deduplicated and ranked candidate evidence bundle together with a reasoning trace describing how the search strategy evolved. The Retriever agent does not itself make compliance decisions; it supplies the retrieval substrate on top of which the audit-specific agents operate.

5.5 Auditor Agent

The Auditor agent performs the primary requirement-level assessment. Its role is to translate an instantiated requirement r_j and its admissible evidence profile $\alpha(r_j)$ into an evidence-acquisition strategy and then synthesize a grounded recommendation from the retrieved evidence.

Evidence Planning. The Auditor begins by constructing an evidence plan from the structured requirement instantiation. The plan specifies:

- (1) the types of evidence to seek;
- (2) the search queries to execute;
- (3) the findings expected from those queries; and
- (4) the criteria for deciding whether the evidence is sufficient.

This step operationalizes the control into an explicit evidence-gathering strategy rather than directly querying the evidence corpus with raw control text.

Evidence Gathering. The Auditor executes the planned queries through the Retriever agent and aggregates the returned evidence into a working evidence pool. Query execution history is retained so that later stages can inspect what was searched, how much

evidence was returned, and whether further search is likely to be productive.

Evidence Evaluation. Once the current plan has been exhausted, the Auditor evaluates whether the gathered evidence is sufficient for a grounded requirement-level determination. If the evidence is relevant but incomplete, the Auditor may append a small number of additional targeted queries. If material gaps remain or no evidence is found, the Auditor terminates retrieval and proceeds to synthesis from the current evidence state.

Finding Synthesis. The synthesis stage produces a structured audit finding containing the predicted status, confidence, summary, detailed reasoning, identified gaps, and recommended follow-up actions. This separation between evidence acquisition and explanation synthesis is a core methodological choice: it constrains the final recommendation to be justified with respect to a bounded evidence bundle rather than unconstrained model intuition.

5.6 Defender Agent

Defense Planning. The Defender is initialized with the auditor's retrieved evidence, planned search queries, and a concise summary of the auditor's reasoning. A defense planner then identifies aspects of the control that may have been underexplored, overly narrow, or insufficiently sensitive to alternative compliant implementations. The result is a small set of defense queries targeted at those missed aspects.

Defensive Retrieval. Defense queries are executed through the same Retriever agent used by the Auditor. Newly retrieved evidence is merged with the auditor's evidence pool rather than treated as a separate corpus. This keeps the defense grounded in the same underlying artifact space as the primary assessment.

Progress Evaluation. After each round of defensive retrieval, the system evaluates whether further search is justified. In contrast to the Auditor, the Defender uses a more aggressive diminishing-returns rule based on recent retrieval yield across defense queries. When recent queries stop contributing enough additional useful material, the defense search is terminated even if the global safety limit has not yet been reached. This is appropriate because the defense stage is conflict-focused and narrow: its purpose is to test whether the initial adverse assessment missed plausible counterevidence, not to repeat the full primary search.

Defense Synthesis. The Defender synthesizes the combined evidence into a structured defense finding containing a suggested revised status, a summary of mitigating evidence, residual gaps, and recommendations. Methodologically, this stage functions as a lightweight adversarial review: before an adverse decision is finalized, the system is given a dedicated opportunity to retrieve counterevidence and reassess the completeness of the initial audit.

5.7 Judge Agent

The Judge agent performs final adjudication when the auditor and defender disagree.

Position Analysis. The Judge begins from the union of auditor and defender evidence, deduplicated before any additional retrieval

occurs. A judgment planner then compares the two positions, identifies their key disagreements, and determines whether the existing evidence is sufficient for final adjudication.

Conflict-Focused Evidence Gathering. If the existing evidence is adequate, the Judge proceeds directly to synthesis. Otherwise, the Judge may issue a small number of additional retrieval queries through the Retriever agent. This retrieval is not intended to duplicate the Auditor's broader evidence-gathering role; instead, it is reserved for resolving specific conflicts or ambiguities that remain after the defense stage.

Final Synthesis. The Judge synthesizes a final structured judgment containing the adjudicated status, confidence, judgment summary, detailed reasoning, degree of agreement with prior agents, and an explicit weighting of the evidence contributed by the auditor, defender, and judge-specific retrieval. This design makes the final decision both independent and auditable: the Judge does not merely select between two prior labels, but reasons over a unified evidence pool.

5.8 Structured Outputs and Workflow Control

All planners and synthesis stages produce structured outputs rather than unconstrained free-form generations. Intermediate artifacts such as search plans, evidence plans, evaluation decisions, defense findings, and final judgments are constrained to fixed fields and enumerated status values. This design reduces prompt drift across stages, enforces stable interfaces between planning, retrieval, evaluation, and synthesis, and improves reproducibility by limiting representational ambiguity at each model invocation.

The overall workflow is orchestrated as an explicit state machine. Each agent maintains internal state describing the current query index, retrieved evidence, reasoning trace, continuation flag, and termination rationale. This makes stopping conditions, adaptive query expansion, and conditional agent invocation explicit at the workflow level rather than leaving them implicit inside a single prompt. Taken together, these design choices yield an evidence-grounded and explainable audit-assistance framework in which retrieval, challenge, and adjudication remain explicitly separated and the final output remains inspectable by auditors.

6 Benchmark

6.1 Audit Framework, Control Selection, and Data Collection

IntelliAudit was designed and evaluated against the ISO/IEC 27001:2022 standard, the third edition of the international standard for information security management systems. This framework was selected for two primary reasons. First, ISO 27001:2022 is normative in character, meaning its controls are precisely and consistently worded, providing a stable semantic surface against which LLM reasoning can be evaluated. This stands in contrast to more flexible frameworks such as the Sarbanes-Oxley Act (SOX) and its associated SOC audit standards, which involve substantial negotiation between auditor and organization over control scoping and selection, making consistent automated evaluation considerably more difficult to operationalize. Second, ISO 27001:2022 is widely adopted across

industries and geographies, meaning that a successful methodology demonstrated on this framework carries broad practical relevance.

The full ISO 27001:2022 standard contains 93 controls spanning organizational, people, physical, and technological domains. Rather than attempting to evaluate all 93, we selected a representative sample of 15 controls, as detailed in Table 1. This sample was constructed deliberately to ensure coverage of the full range of artifact types that appear in real-world IT audits, including plain-text and formatted documents, structured spreadsheet data, images, and video. This multimodal selection was important because we anticipated that LLM performance would vary meaningfully by artifact type, and we wanted our evaluation to surface those differences rather than obscure them by limiting the dataset to a single artifact category. The specific controls selected span policy documentation (5.1, 5.29, 5.30), role and responsibility assignment (5.2), asset management (5.9, 5.11), incident management lifecycle (5.24, 5.25, 5.26, 5.27), personnel process enforcement (6.4), and physical and technical controls (7.7, 7.14, 8.1, 8.4).

Because IT audit evidence is inherently sensitive and rarely made publicly available by organizations, we constructed a simulated organization to serve as the subject of the audit. This organization was given a realistic executive structure, including a Chief Executive Officer (James Byrne), Chief Information Security Officer (Sarah Johnson), Chief Technology Officer (David Thompson), Chief Operations Officer (Robert Chen), Chief Financial Officer (Lisa Martinez), and Chief Human Resources Officer (Amanda Taylor). These roles and their associated responsibilities were defined in accordance with governance guidance from NIST SP 800-100 and the role definitions embedded in the organization's own information security policy, which was itself generated as part of the artifact corpus. Establishing a consistent and credible organizational identity before generating any evidence artifacts was essential, as all subsequent synthetic documents, disciplinary records, and procedural evidence were grounded in this shared organizational context, which is what gives them their internal coherence and audit credibility.

The dataset assembled for this study was organized into three tiers: Real World Data, Expert Crafted Data, and Synthetic Data. This taxonomy reflects the practical reality that building a comprehensive ISO 27001 audit dataset from purely organic sources is not feasible, given the sensitive nature of the material involved. Real World Data consists of publicly available authoritative documents that provide the normative and procedural foundation for the entire dataset. These include the ISO/IEC 27001:2022 standard itself, the Province of British Columbia's Information Security Policy (version 5.0, August 2025), NIST SP 800-61 Revision 3 (Computer Security Incident Handling), NIST SP 800-34 Revision 1 (Contingency Planning), and NIST SP 800-100 (Information Security Handbook for Managers). These documents were used both as direct evidence where appropriate and as seed material for synthetic generation, ensuring that all generated artifacts were grounded in real-world regulatory and procedural language rather than produced from the model's priors alone.

Expert Crafted Data consists of artifacts created by the research team to simulate the kinds of evidence that organizations produce operationally but rarely disclose publicly. This tier includes the organizational chart for the simulated company, asset inventory spreadsheets covering multiple simulated organizational profiles

at varying levels of compliance maturity (from compliant to non-compliant), a video artifact for clear desk and clear screen policy testing, and screenshots representing user access provisioning and source code repository permissions. These artifacts were created with care to reflect realistic enterprise patterns; for example, asset inventories were constructed to reflect consistent vendor procurement relationships, realistic geographic distribution across Canadian cities, and appropriate data center configurations, rather than random data that would fail to reflect how real organizations actually operate.

Synthetic Data consists of policy and procedural documents generated by an LLM using the Real World and Expert Crafted artifacts as seed inputs. For each synthetically generated artifact, a consistent baseline prompt was used: "You are generating data samples for use in an ISO 27001:2022 audit. Use the files uploaded in the project as context for the generated data samples." This was then supplemented by a control-specific prompt that directed the model toward the appropriate document type, organizational voice, and compliance objective. All synthetic generation was performed using Claude Sonnet 4.5 with the organizational chart and the relevant ISO controls provided as mandatory seed context in every generation call. The synthetic artifacts produced through this process include the organization's Information Security Policy (Control 5.1), Business Continuity Plan (5.29), ICT Readiness Plan (5.30), Incident Management Policy (5.24), Incident Response Report (5.27), and a three-document disciplinary evidence chain for Control 6.4 consisting of a verbal warning, a written warning, and a termination letter, all involving a consistent fictitious employee and following a progressive enforcement narrative across the three documents. The complete artifact inventory is detailed in Tables 2 and 3 in Appendix A, with each artifact's data tier, seed inputs, and generation prompt documented for reproducibility.

6.2 Survey Design

System performance was evaluated using a two-pronged approach designed to guard against both model-specific bias and purely automated assessment. For the primary evaluation, INTELLIAUDIT used OpenAI's GPT-5-Nano as the underlying inference model. Outputs from GPT-5-Nano were then independently evaluated using Claude Sonnet 4.5 for text-based evidence artifacts, providing a cross-model validation layer that reduces the risk of systematic errors attributable to any single model's particular reasoning tendencies or training distribution.

Ablation Study We reran our pipeline with only the auditor agent. We then presented both reasoning outputs to the Auditors in our Human Survey.

Human Survey As we have no ground truth and to prevent AI bias, we worked with practicing auditors to get their professional evaluations as auditors as well as second year Cybersecurity Master's students and current compliance professionals to simulate a member of an organization using INTELLIAUDIT to remedy organizational deficiencies in preparation for an audit. Group A, Auditors were asked questions to get their professional opinion on if the model's reasoning was correct. Group B, were asked a series of questions about the usefulness of the model's output in correcting or updating evidence to meet control requirements. Their responses,

#	Control Name	Artifact
5.1	Policies for information security	DOC
5.2	Information security roles and responsibilities	PDF
5.9	Inventory of information and other associated assets	XLS
5.11	Return of assets	XLS
5.24	Information security incident management planning and preparation	DOC
5.25	Assessment and decision on information security events	DOC
5.26	Response to information security incidents	DOC
5.27	Learning from information security incidents	DOC
5.29	Information security during disruption	DOC
5.30	ICT readiness for business continuity	DOC
6.4	Disciplinary process (AKA Three Strike Policy)	TXT, PNG
7.7	Clear desk and clear screen	DOC, MP4
7.14	Secure disposal or re-use of equipment	PDF
8.1	User endpoint devices	PNG
8.4	Access to source code	PNG

Table 1: ISO 27001 Controls and Associated Artifacts

documented in Appendix B, serve as the ground-truth reference against which both models’ outputs are compared, and provide a human benchmark that reflects the professional standards an automated system must ultimately meet to be useful in practice.

6.3 Survey Results

The questionnaire and the auditor’s reasoning can be found in Appendix B <Update Appendix Letter>.
<INSERT CHART HERE>

6.4 Experiment

Conclusion
text<TEXT>

7 Conclusion

Conclusion
Both Claude-Sonnet-4.5 and GPT-5-nano were able to evaluate all of our artifacts except the MP4 due to context window size limitations.

Conclusion
<TEXT>

A Tables

#	Artifact	Control #	Data Type
R1	ISO_IEC_27001_2022en.pdf	N/A	Real World
R2	BC_isp_v50_aug2025.pdf	N/A	Real World
R3	NIST SP 800-61 Rev 3.pdf	N/A	Real World
R4	NIST SP 800-34r1.pdf	N/A	Real World
R5	NIST SP 800-100.pdf	N/A	Real World
E1	5-2_Org_Chart.pdf	5.2	Expert Crafted
E2	C_Global_Enterprises_Inc_Asset_Inven- tory.xls	5.9, 5.11	Expert Crafted
E3	SC_GlobalFinance_Partners_Asset_- Data.xlsx	5.9, 5.11	Expert Crafted
E4	SC_QuickServe_Restaurants_LLC_Asset_- Data.xl	5.9, 5.11	Expert Crafted
E5	SC_TechInnovate_Inc_Asset_Data.xlsx	5.9, 5.11	Expert Crafted
E6	SC_WestRange_Logistics_Inc_Asset_- Data.xlsx	5.9, 5.11	Expert Crafted
E7	NC_BuildRight_Construction_Asset_- Data.xlsx	5.9, 5.11	Expert Crafted
E8	NC_MetroRetail_Group_Asset_Data.xlsx	5.9, 5.11	Expert Crafted
E9	7-7_cover-a-guy-working-on-a-pc-18- 1080p.mp	7.7	Expert Crafted
E10	8-1_Okta_User_List.png	8.1	Expert Crafted
E11	8-4_Code_Repo_Access_List.png	8.4	Expert Crafted

Table 2: Non-Synthetic Data: Real World and Expert Crafted Artifacts

#	Artifact	Control #	Data Type	Seed	Model	Additional Prompt
S1	5-1_informa- tion_security_- policy.docx	5.1	Synthetic	E1, R1, R4	Sonnet_4.5	This is the Information Security policy for the Provencal Government of British Columbia. Please adapt the Information Security policy to fit my organization and ensure it is compliant with NIST SP 800-100.
S2	5-29_BCP	5.29	Synthetic	E1, S1, R1, R4	Sonnet_4.5	Based on the attached artifacts, please create a Business Continuity Plan for my organization.
S3	5-24_Incident_- Management_- Policy.docx	5.24	Synthetic	E1, S1, R1, R3	Sonnet_4.5	Attached is the NIST Standard for incident response. Please create for my org an Incident Management Policy in accordance with ISO27001 control 5-24.
S4	5-27_incident_- response_re- port.docx	5.27	Synthetic	E1, S1, S3, R1, R3, R	Sonnet_4.5	Attached is my Incident Management Policy and the NIST standard for incident response. Please create for me an incident response report.
S5	6-4_Verbal_- Warning.txt	6.4	Synthetic	E1, S1, R1, R5	Sonnet_4.5	I am trying to create examples of a three strike policy in action. Please create for me an email from Sarah Johnson (CISO) to Amanda Taylor (CHRO) documenting the fact that Sarah reprimanded Joseph Thomas (on the IT Operations team) for an Information Security policy violation.
S6	6-4_Written_- Warning.txt	6.4	Synthetic	E1, S1, S5, R1, R5	Sonnet_4.5	It seems that Joseph Thomas has once again violated policy. Please create a written warning for similar but difference violations of the Information Security Policy.
S7	6-4_Termina- tion_Letter.txt	6.4	Synthetic	E1, S1, S5, S6, R1, R5	Sonnet_4.5	It seems Joseph Thomas is a problem employee and has for a third and final time violated the Information Security policy. Please generate a formal termination letter written from Amanda Taylor to Joseph Thomas.

Table 3: Synthetic Data: AI-Generated Audit Artifacts

B Survey Responses

References